

## 访问控制漏洞报告（Lab5：用户 ID 由请求参数控制，用户 ID 不可预测）

### 1. 漏洞名称

不安全的直接对象引用（IDOR / Insecure Direct Object Reference）— 基于 GUID 的水平越权

### 2. 漏洞等级

高危（High）

### 3. 漏洞描述

该网站的个人中心页面通过不可预测的 GUID（全局唯一标识符）作为 id 参数来识别用户。然而，虽然 ID 不可直接遍历，但该 GUID 在公开的博客文章作者超链接中被暴露。攻击者通过收集其他用户的公开 GUID，替换个人中心 URL 参数，即可绕过服务端权限校验，横向越权查看他人敏感信息（如 API 密钥）。

### 4. 漏洞位置

信息泄露点：公开博客文章页面的作者链接（/blogs?userId=...）

越权访问路径：/my-account?id=[目标用户 GUID]

### 5. 漏洞复现过程

#### 第一步：正常登录与初步信息收集

使用提供的测试账号 wiener:peter 登录进入个人中心，确认当前自己账户的 GUID 与 API 密钥。

图 1：正常登录个人账户

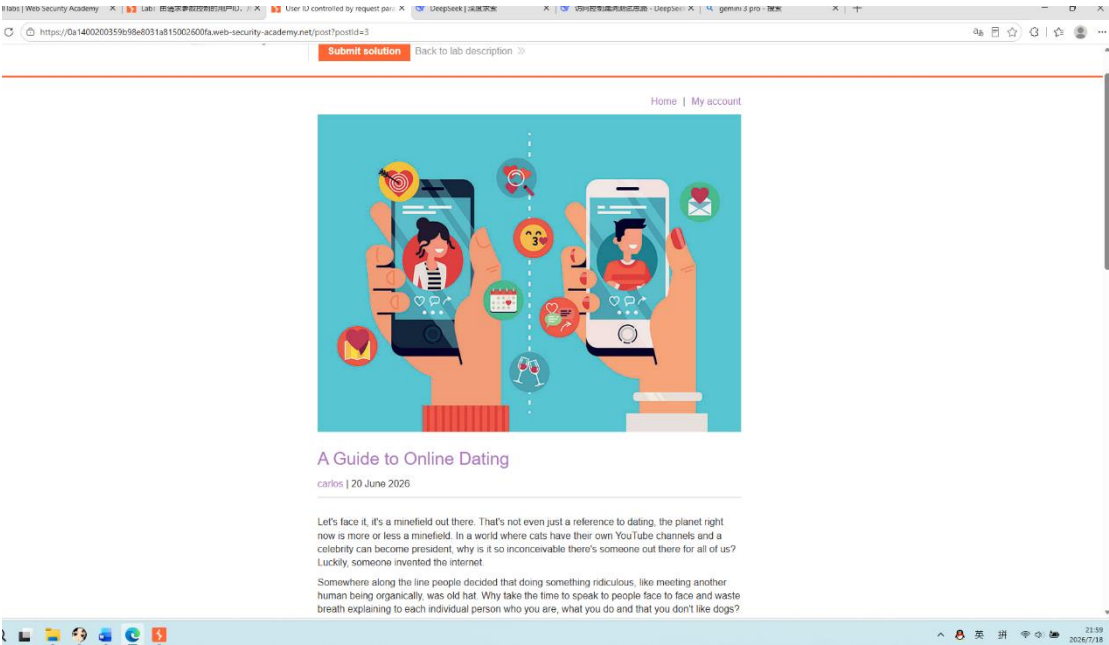


说明：正常登录，准备寻找目标用户 carlos 的信息。

第二步：在公开博客中发现不可预测 ID（GUID）

访问博客列表，点击 carlos 发布的博客文章《A Guide to Online Dating》。

图 2：发现目标用户的博客文章



说明：在公开内容中定位到了 carlos。

点击 carlos 这个作者名字，页面跳转至该作者的全部文章列表。注意观察此时浏览器地址栏的 URL。

图 3：在 URL 中提取隐藏的不可预测 GUID



说明：发现攻击者目标 carlos 的隐藏 ID 是一个长字符串形式的 GUID，且该信息直

接暴露在了公开的博客作者链接中。

### 第三步：利用 GUID 实施水平越权

将浏览器地址栏路径修改为个人中心接口，并将 id= 参数替换为刚才提取到的 carlos 的 GUID。

请求路径：/my-account?id=4891b5ef-0496-434e-85d6-3c730e849b0b

图 4：成功越权访问目标用户的个人中心



说明：后端仅校验了 GUID 是否存在，但未校验当前登录的 wiener 用户是否有权限查看该 GUID 对应的数据。成功横向越权获取了 carlos 的 API 密钥。

### 第四步：提交密钥，解决实验

复制目标用户的 API 密钥，粘贴到实验页面上方的“提交解决方案”并提交。

图 5：成功解决实验



说明：实验验证完成。

## 6. 漏洞原理

该漏洞属于防护失效导致的不安全直接对象引用：

1. **安全误区**：开发者误以为只要不使用自增数字 1, 2, 3，而是换成复杂的 GUID 字符串，就足够安全，因此省略了后端的权限校验。
2. **漏洞产生**：尽管攻击者无法遍历猜出 GUID，但这个 GUID 作为一种资源标识符，被直接写在了公开博客的链接参数中。任何访问公开网页的用户都能轻易获取。
3. **越权发生**：后端 API 在处理 /my-account 时，仅执行了类似 `SELECT * FROM users WHERE id = 'GUID'` 的查询，缺乏对当前登录用户身份的强校验。

## 7. 漏洞影响

- **敏感数据批量泄露**：攻击者可以爬取公开博客的作者列表，收集所有用户的 GUID，进而批量窃取所有用户的 API 密钥、私人信息等。
- **隐私破坏**：ID 隐藏策略无效，导致所有通过隐藏 ID 试图保护的敏感数据被泄露。

## 8. 修复建议

- ① **强制服务端权限校验（核心）**：后端在处理涉及用户敏感数据的 API 时，**必须校验** URL 参数中的目标 ID 是否与当前登录 Session 中的用户 ID 一致。如果不一致，直接返回 403 Forbidden。
- ② **取消前端传参**：如果是“查看自己信息”的操作，后端应该直接从 Session 中读取用户 ID 进行查询，完全忽略前端传入的 id 参数。

③ **URL 可预测性校验**：在公开页面（如博客列表）中，不要直接将用户 ID 作为 URL 参数暴露，可使用不具业务含义的哈希值映射。

## 9. 工具

- **Google Chrome / Firefox**（查看网页源码、公开链接与抓包）
- **PortSwigger Web Security Academy**（靶场平台）